

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Siyakhula Community Foundation

Report reference RPT-MKFRS-V12-COMP-SIYAKHULA-V1
Generated 23 August 2026
Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	7
Priority findings, contradictions and scenarios	9
Priority risks	15
Leadership decisions and roadmap	18
Proof requirements	21
Methodology, limitations and next steps	22
Appendix: supporting material	23
Complete supporting detail	23
E1. Supporting control actions	23
E2. Definitions and score basis	27

Executive summary

Fraud controls are not yet consistently embedded.

Reported readiness

43

out of 100

Developing

Overall readiness position

The assessment places Siyakhula Community Foundation at 42.73/100 with a Developing maturity. Within that profile, governance-related areas report comparatively stronger positions: leadership and governance processes and the whistleblowing/reporting culture are reported as relative strengths. At the same time, detection, continuous improvement and digital-identity risk domains score materially lower and concentrate the most significant practical gaps. The strongest assessed capabilities therefore offer a management foothold for organising work, while the weaker detection and monitoring, supplier and identity controls, and the review cadence require connection into that foothold to reduce exposure.

This assessment is derived from management's own responses and the MK scoring method; it is a strategic analysis of fraud risk and control design and does not constitute independent verification of operating effectiveness.

What is shaping the readiness position

A small set of connected themes explains how the Developing maturity arises. First, fraud governance and risk-discipline are only partly converted into repeatable, process-level ownership, so process exposures can remain unmapped and ownerless. Second, detection and monitoring coverage is limited: suspicious digital activity and rule-based analytics are either absent or informal, leaving unusual access and transaction patterns without a reliable central route for triage. Third, identity verification and sensitive-change checks are not consistently enforced, increasing reliance on manual or ad hoc validation. Fourth, incident response and evidence-preservation arrangements are informal in places, which reduces the organisation's ability to contain and learn from suspected matters. Finally, supplier and payment on-boarding and conflict-declaration activity is inconsistent, creating a potential route for supplier or payment diversion if activation and bank changes are not independently verified. Those themes together create the visibility and treatment gaps that underpin the score.

What this means for management

The score indicates a clear priority: convert relative governance strength into disciplined, process-level ownership and a repeatable operating rhythm that closes the detection, verification and evidence-preservation gaps. Management should treat this as a starting point for structured remediation rather than as confirmation that controls already operate in practice.

COVERAGE

100%

CRITICAL GAPS

11

MAJOR GAPS

4

Assessment scope and limitations

APPLICABLE CONTROLS

66

CONTROL VISIBILITY

100%

EXCLUDED AREAS

2

UNCERTAINTY RESPONSES

0

The result reflects the control areas applicable to the organisation. Valid scope exclusions and oversight-routed controls are part of the adaptive assessment design; differences in assessed scope may limit direct comparison with other assessments.

4 control areas were completed using the assessment's oversight question set rather than the standard question set. They remain in the scored scope. Excluded areas are outside the assessed scope and are not treated as weaknesses.

The aggregate result and its ten underlying domains

The Developing result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.



What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL GAP · CONTINUOUS IMPROVEMENT AND FRAUD RISK MONITORING

The organisation periodically reviews its fraud risks and control environment.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation’s important processes.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

System and data access is granted against current role requirements.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

Access to sensitive systems, administrator rights and confidential data is restricted.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

The organisation can detect identity misuse, account takeover or impersonation.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

Where a strong average can still hide a real gap

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · CONTINUOUS IMPROVEMENT AND FRAUD RISK MONITORING

The organisation periodically reviews its fraud risks and control environment.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Core domain Fraud Risk Identification scored below 40.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Core domain Fraud Risk Identification scored below 60.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

A domain score is an average. It can still contain one specific control that is materially weaker than the others feeding into the same number. The purpose of this report is to surface that unevenness so leadership does not treat the overall score as a substitute for control-level attention.

Domain overview

The systemic pattern

The assessment points to one systemic shortfall: governance exists but is not yet translated into sustained, evidence-backed operating discipline across the value-bearing processes that create exposure. Process-level fraud mapping is informal or reactive, so specific fraud scenarios are not consistently tied to named control owners and controls are not systematically tested. Detection and monitoring capabilities are underdeveloped or ad hoc, leaving digital-identity events and transaction populations without a comprehensive rule catalogue, triage and escalation route. Identity verification and supplier onboarding are partly designed or inconsistently applied, which increases the chance that a supplier or beneficiary change is not independently challenged before funds move. Incident response and evidence-custody arrangements are informal in places, so records from suspected matters may not be preserved under controlled custody for effective investigation or learning. These relationships create a reinforcing loop: controls that are assumed to exist may have lapsed, monitoring backlogs accumulate without assigned reviewers, evidence is not consistently sealed or logged, and the absence of an evidence-led review cycle delays the identification and remediation of degraded controls. Leadership attention and governance therefore need to be translated into named accountable owners, per-process mapping, defined monitoring coverage and an evidence-preservation route if the current position is to improve.

Foundations: ownership, awareness and reporting culture

Executive ownership, risk identification, workforce awareness and safe reporting.

Fraud Leadership and Governance

62/100

Structured reported position.

Fraud Risk Identification

39/100

Reactive reported position.

Critical condition: Fraud risks are mapped to the organisation's important processes.

Fraud Culture and Awareness

77/100

Structured reported position.

Whistleblowing and Reporting Culture

81/100

Strategic reported position.

Operational defence: controls, detection and third parties

Day-to-day prevention, detection and supplier-facing control operation.

Operational Fraud Controls

41/100

Developing reported position.

Priority condition: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

Critical condition: System and data access is granted against current role requirements.

Fraud Detection Capability

21/100

Reactive reported position.

Priority condition: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags.

Priority condition: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

Third-Party and Supply Chain Fraud Risk

47/100

Developing reported position.

Response and evolution: incidents, digital risk and improvement

Incident response, digital and identity defence, and continuous control improvement.

Fraud Incident Response

44/100

Developing reported position.

Priority condition: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Digital and Identity Fraud Risk

26/100

Reactive reported position.

Priority condition: The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm.

Priority condition: The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.

Critical condition: Access to sensitive systems, administrator rights and confidential data is restricted.

Priority condition: The organisation can detect identity misuse, account takeover or impersonation.

Reactive reported position.

Priority condition: The organisation periodically reviews its fraud risks and control environment.

PRIORITY FINDINGS, CONTRADICTIONS AND SCENARIOS

Priority findings, contradictions and scenarios

8 conditions were selected for executive attention from 34 recorded findings. The complete register of all 34 findings is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx).

Role distinction: Control owner identifies the role responsible for implementing or operating the control. Accountable executive identifies the executive role responsible for sponsorship, decision rights and escalation. The two roles may legitimately differ.

Value diversion through supplier and payment processes

Supplier onboarding and pre-activation checks are only partly designed. Without an enforced pre-activation checklist that independently verifies legal identity, beneficial ownership, bank details and conflicts of interest, a fictitious or conflicted supplier can be activated and used to receive payments. Management implication: supplier activation and bank-detail changes must be blocked until independent verification and a second reviewer approval are retained in the vendor master.

Weak challenge at identity, transaction and sensitive-change points

Monitoring for suspicious digital access and analytics-based transaction checks are either absent or informal. Where digital-activity monitoring is not in place and analytic checks are reactive, unusual login, profile or transaction patterns can persist without triage and escalation. Similarly, identity-verification points and rules for sensitive profile or banking changes are not consistently applied. Management implication: implement a defined monitoring cycle with named exception reviewers and SLAs, and make sensitive-profile and bank-detail changes subject to re-verification before release.

Limited containment and learning after suspected fraud

Evidence identification, preservation and handling are assessed as informal or reactive in places. When evidence is not collected under controlled custody, hashed or logged through every transfer, investigations and any recovery or disciplinary action are harder to pursue effectively. Management implication: establish a defined intake and preservation route and ensure custody records are created for every material suspected matter so incidents are contained and yield organisational learning.

Additional material control pattern

Role-based access governance and conflict-of-interest declarations are partly designed or informal. Access granted without current role justification and conflicts of interest handled reactively create an environment where stale rights or undisclosed supplier relationships can enable or mask unauthorised initiation, approval or supplier steering. Management implication: reconcile access to role responsibilities on a defined cycle and require annual and on-change conflict declarations for in-scope roles, with testing against the vendor master.

MATERIAL FINDING 1

MATURITY CONSTRAINT

Fraud Risk Identification: Fraud risks are mapped to the organisation’s important processes.

DOMAIN

Fraud Risk Identification

ASSESSED CONTROL STATE

Fraud risks are mapped to the organisation’s important processes.
— Informal / reactive

DIAGNOSIS

Process-level fraud risk mapping was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner with named process owners

IMPLEMENTATION

Moderate difficulty · 90 days

MATERIAL FINDING 2

PRIORITY CONTROL WEAKNESS

Digital and Identity Fraud Risk: The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel.

DOMAIN

Digital and Identity Fraud Risk

DIAGNOSIS

Suspicious digital-activity monitoring was self-assessed as "Not in place" (The capability is absent or is not recognised as required; normalised score 0/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel. — Not in place

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Security monitoring / the security monitoring function

IMPLEMENTATION

High difficulty · 90 days

MATERIAL FINDING 3

PRIORITY CONTROL WEAKNESS

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

DOMAIN

Fraud Incident Response

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Investigation lead / Evidence custodian

IMPLEMENTATION

High difficulty · 60 days

MATERIAL FINDING 4

MATURITY CONSTRAINT

Continuous Improvement and Fraud Risk Monitoring: The organisation periodically reviews its fraud risks and control environment.

DOMAIN

Continuous Improvement and Fraud Risk Monitoring

DIAGNOSIS

Periodic fraud risk and control environment review was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

The organisation periodically reviews its fraud risks and control environment. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner

IMPLEMENTATION

Moderate difficulty · 90 days

MATERIAL FINDING 5

PRIORITY CONTROL WEAKNESS

Fraud Detection Capability: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

DOMAIN

Fraud Detection Capability

DIAGNOSIS

Analytics and rule-based detection was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Fraud analytics owner

IMPLEMENTATION

High difficulty · 90 days

MATERIAL FINDING 6

PRIORITY CONTROL WEAKNESS

Operational Fraud Controls: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Supplier-onboarding verification was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ASSESSED CONTROL STATE

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. — Partly designed

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Procurement / Vendor Master

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 7

PRIORITY CONTROL WEAKNESS

Operational Fraud Controls: System and data access is granted against current role requirements.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Role-based user-access governance was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

System and data access is granted against current role requirements. — Partly designed

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Business system owners

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 8

CROSS-DOMAIN DEPENDENCY

Third-Party and Supply Chain Fraud Risk: Employees are required to disclose and manage conflicts of interest involving suppliers or third parties.

DOMAIN

Third-Party and Supply Chain Fraud Risk

DIAGNOSIS

Conflict of interest declaration and management was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

ASSESSED CONTROL STATE

Employees are required to disclose and manage conflicts of interest involving suppliers or third parties. — Informal / reactive

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

RECOMMENDED CONTROL

The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Legal / investigations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

CONTROL OWNER

Compliance with Human Resources

IMPLEMENTATION

Moderate difficulty · 60 days

Contradictions

CONTRADICTION 1

Operational and privileged-access weaknesses indicate one systemic access-governance issue

WHAT THE ASSESSMENT SHOWS

Digital and Identity Fraud Risk — Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent; Operational Fraud Controls — Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

WHY IT MATTERS

Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.

LEADERSHIP VERIFICATION

Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

Conditional exposure pathways

These pathways are conditional tests that show where prevention, detection and containment must interrupt a sequence of contributing weaknesses. They do not allege an event but help management test whether controls will work under plausible combinations of the assessed gaps.

UNUSUAL ACTIVITY AVOIDS TIMELY CHALLENGE BECAUSE MONITORING OR ESCALATION COVERAGE IS INCOMPLETE

A central risk is that unusual activity in a single operating location or channel falls outside the modest or ad hoc monitoring coverage and is therefore triaged locally, if at all. In that environment, repeated low-value or threshold-adjacent transactions, out-of-hours approvals or location-specific anomalies can persist because rule coverage and cross-population comparison are incomplete. Warning indicators include unexecuted rules for a full monitoring cycle, a growing alert backlog without assignment, or repeated threshold-adjacent activity. Immediate containment should assign and triage affected alerts, preserve the relevant activity record and escalate overdue items. Longer-term response is to define monitoring coverage, red flags, reviewer ownership, closure-evidence requirements and a formal overdue-escalation route so anomalous activity becomes visible and acted on.

RECORDS OR REPORTING ARE WEAKENED AFTER A SUSPECTED FRAUD MATTER, ALLOWING EXPOSURE TO REPEAT

When a suspected matter is raised at a local site but evidence preservation, legal-hold and custody are not consistently applied, the available records can be incomplete, moved or altered before a central intake is established. This makes reconstruction and containment harder and increases the chance of repeat exposure. Warning indicators are reports delivered through channels controlled by the implicated process, unavailable records or unclear custody, and overdue severity or containment decisions. Immediate containment is to open an incident record, preserve relevant records under controlled custody and assign a named containment and investigation owner. Long-term response is to implement protected reporting channels, severity-based escalation, formal evidence-preservation procedures and a repeat-exposure review that converts cases into programmatic lessons.

A credible supplier bank-detail change submitted shortly before a scheduled payment can divert value if supplier activation and bank changes are not independently verified. The mechanism relies on ordinary-looking vendor activity and the absence of a mandatory independent verification step. Warning indicators include a new or reactivated supplier prior to verification, a bank-detail change shortly before payment, or an urgent payment request that circumvents the normal callback route. Immediate containment is to pause the affected supplier or payment instruction, independently confirm the trusted beneficiary details through an independent channel and preserve the approval trail. Longer-term response is to implement independent supplier and bank-detail verification, dual approval for payment-critical changes, and complete population monitoring of supplier activation and reactivation.

PRIORITY RISKS

Priority risks

Risk priority is produced by the MK qualitative likelihood/impact matrix. Risks sharing the same priority class are not more finely ranked by their display order. Likelihood and impact are qualitative descriptors, not statistical probabilities. The complete risk register (33 risks) is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx).

RISK 1 · CONTINUOUS IMPROVEMENT AND FRAUD RISK MONITORING

CRITICAL

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

Because the self-assessment records "The organisation periodically reviews its fraud risks and control environment" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier. Consequence pathway: Control ownership, evidence and remediation can lapse as processes, systems or responsibilities change; Undetected control deterioration can allow loss exposure to persist or compound before management intervenes.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Continuous Improvement and Fraud Risk Monitoring: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The Risk / compliance accountable owner must run a scheduled review that revisits the fraud risk assessment for continued relevance, confirms for each key control that it still has a named owner and is still operating by sampling recent evidence rather than accepting attestation, records any control that has lapsed or degraded, and reports a consolidated risk and control position to the governing body with owned remediation actions and due dates.

ACCOUNTABLE EXECUTIVE

CEO / Managing Director

TARGET PERIOD

90 days

RISK 2 · FRAUD RISK IDENTIFICATION

CRITICAL

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as stock write-off manipulation is never mapped to a control owner.

Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as stock write-off manipulation is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Risk Identification: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

TARGET PERIOD

90 days

RISK 3 · FRAUD DETECTION CAPABILITY

CRITICAL

As transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation.

Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that as transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Detection Capability: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

TARGET PERIOD

90 days

RISK 4 · DIGITAL AND IDENTITY FRAUD RISK

CRITICAL

Digital account compromise or misuse is not detected promptly

Because material login, access, profile and transaction events are not completely monitored and triaged, there is a risk that a compromised or malicious identity uses digital channels without timely detection and response. Consequence pathway: customers and partners lose trust in digital channels; digital operations must contain and investigate a wider incident; security or personal-data notification duties may arise; unauthorised transactions or account changes cause direct loss.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Digital and Identity Fraud Risk: Not in place — The capability is absent or is not recognised as required

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.

TARGET PERIOD

90 days

RISK 5 · FRAUD INCIDENT RESPONSE

CRITICAL

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Incident Response: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

TARGET PERIOD

60 days

RISK 6 · OPERATIONAL FRAUD CONTROLS

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

60 days

LEADERSHIP DECISIONS AND ROADMAP

Leadership decisions and roadmap

Target control environment

Strengthen fraud-risk identification and treatment

Management should convert the informal process-level mapping into a completed, signed per-process fraud map that ties specific fraud scenarios to the roles and system permissions that can execute them, documents preventive and detective controls, and records residual gaps. The target control response is a process-by-process fraud map refreshed on change, owned by named process owners and evidence-tested rather than accepted by attestation alone. Completion is the evidence standard that 100% of material value-bearing processes have a signed fraud map with named controls and residual gaps; any unmapped process or unowned residual gap triggers escalation.

Strengthen supplier onboarding and identity checks

Supplier activation must be subject to a pre-activation checklist that evidences independent registration and bank ownership verification, beneficial ownership and conflict screening, risk rating, and a second-reviewer approval held in the vendor master. The target control response blocks ERP activation until the evidence pack and second review are present. The completion test is that 100% of newly activated suppliers have a complete pre-activation evidence pack and independent approval.

Strengthen role-based access and segregation

Access provisioning should follow a current role-to-access matrix, require business-owner approval against current duties, separate initiation and approval rights, and retain provisioning trails. The target control response includes quarterly reviews and reconciliation on every joiner, mover or leaver event. The effectiveness measure is a complete population review quarterly and 95% of removal exceptions closed within 10 business days; missed reviews or overdue removals trigger escalation.

Strengthen monitoring, exception review and escalation

Risk-based monitoring must cover priority digital and transaction event feeds, maintain a rule catalogue that links each test to a fraud scenario, assign alerts to trained analysts, preserve disposition evidence and tune rules monthly based on confirmed outcomes. The target control response sets SLAs for triage and escalation and reconciles monitoring outputs to source populations. Completion is demonstrated when all priority event feeds are monitored and 95% of high-risk alerts are triaged within SLA; priority feed outages, high-risk alerts outside SLA or un-escalated compromises require immediate remedial action.

Strengthen evidence preservation and custody

For every material suspected matter an investigation lead must open an evidence register, deploy trained custodians, create forensic copies or sealed originals, record hashes or seal numbers and every transfer, and store evidence in access-controlled repositories. The target control response is an auditable chain-of-custody process with retention and legal-hold instructions where required. The completion test is that 100% of sampled material-case evidence has a complete custody trail and matching integrity check; unexplained custody gaps or integrity mismatches trigger escalation to Legal.

Strengthen control learning and continuous improvement

A scheduled review must reassess fraud risks, sample key-control operating evidence rather than relying on attestation, record lapsed or degraded controls and report a consolidated position with owned remediation actions to governance. The target response is a repeatable review cadence that converts incidents and near-misses into aggregated themes and

programme-level actions. Completion is the evidence that every key control is tested within the review cycle and that lapses are remediated by their due dates.

Leadership decisions required

Every decision below carries a defined accountable executive role and a fixed target period; each is grounded in the material findings, risks and controls set out in this report and in the complete registers in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx).

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	60 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Finance / operations accountable owner	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	CEO / Managing Director	60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

30/60/90-day roadmap

The first 30 days establish decisions and ownership; the 60- and 90-day windows implement and evidence the linked controls.

By 30 days — Stabilise

The immediate priority is to stabilise intake, custody and escalation so suspected matters are handled under a controlled route. Establish chain-of-custody forms, an evidence register and secure repository access controls so that preservation begins the moment a concern is raised. Proof of completion is the presence of the evidence register, chain-of-custody entries, hash or seal records and a repository access log for any material matter opened during the window.

First 30 days — decisions and foundations

PRIORITY DECISION	DELIVERABLE	ACCOUNTABLE EXECUTIVE	COMPLETION TEST
Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	Signed mandate names each accountable executive, decision rights and the escalation route.
Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	Approved control-improvement baseline records the required design standard and any authorised deviations.
Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	Dependency sequence is approved with named prerequisite owners and escalation for threatened dependencies.

First 30 days — implementation foundations

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Any unexplained custody gap, integrity mismatch or unauthorised repository access.	Legal / investigations accountable owner / Finance / operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.

By 60 days — Establish

By the end of the second month, management should define and begin implementing priority preventive controls that block the most direct exposure routes. This includes requiring independent verification for supplier activation and bank-detail changes, reconciling joiner/mover/leaver events against access, and confirming resource allocation to monitoring and investigative capacity. Successful establishment is shown by complete pre-activation evidence packs for newly activated suppliers and evidence that access review and reconciliation processes are operating against the stated populations.

60-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any supplier activated before verification or any ownership/conflict match unresolved.	Finance / operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.	Finance / operations accountable owner	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
Third-Party and Supply Chain Fraud Risk	Implement the target control design for Third-Party and Supply Chain Fraud Risk. Escalation trigger: An employee-supplier match not investigated, or a declared conflict with no management action.	Finance / operations accountable owner / Legal / investigations accountable owner	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.

By 90 days — Operate and review

In the 31–90 day window convert the stabilised and established elements into operating routines: run the fraud-risk and control-environment review, put the monitoring rule catalogue into continuous operation with monthly tuning, and evidence-test key controls within the review cycle. Reporting from these activities should be consolidated and presented to governance through the agreed cadence so progress and any residual gaps are visible. Completion is demonstrated by consolidated governance reports, samples of key-control operating evidence, monitoring logs and the rule-tuning record.

90-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Risk Identification	Implement the target control design for Fraud Risk Identification. Escalation trigger: Any material process unmapped, or a mapped residual gap with no owner.	Finance / operations accountable owner	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
Continuous Improvement and Fraud Risk Monitoring	Implement the target control design for Continuous Improvement and Fraud Risk Monitoring. Escalation trigger: Review overdue, or a key control found lapsed with no remediation owner.	CEO / Managing Director	Every key control is evidence-tested within the review cycle, with lapses remediated by due date.
Digital and Identity Fraud Risk	Implement the target control design for Digital and Identity Fraud Risk. Escalation trigger: Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated.	Technology / security accountable owner	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
Fraud Detection Capability	Implement the target control design for Fraud Detection Capability. Escalation trigger: A priority scenario with no operating check, or rules unexecuted for a full cycle.	Finance / operations accountable owner / Technology / security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

Management conclusion

The assessed position is a starting point for structured management attention: governance and reporting culture are relatively stronger and provide an organising anchor, but detection, digital-identity checks, supplier activation, evidence custody and review cadence are the priority areas requiring owned treatment. Management should convert the relative governance strength into named accountable ownership, complete per-process fraud mapping, defined monitoring and evidence-preservation routes, and a scheduled control-effectiveness review so the current Developing maturity can be progressed toward a more resilient, evidence-backed operating posture.

PROOF REQUIREMENTS

Proof requirements

The items below are the immediate proof requirements linked to the priority findings above. The complete evidence checklist is not reproduced in this report; it is provided in full in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx).

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Risk / compliance accountable owner with named process owners	Not yet requested
2	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Risk / compliance accountable owner with named process owners	Not yet requested
3	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Risk / compliance accountable owner with named process owners	Not yet requested

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
4	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Risk / compliance accountable owner with named process owners	Not yet requested
5	Alert case records	Whether suspicious digital-activity alerts are assigned, investigated, dispositioned and escalated to the required service level.	Security monitoring / the security monitoring function	Not yet requested
6	In-scope event inventory	Whether the complete population of priority login, access, profile and transaction events has been identified for monitoring.	Security monitoring / the security monitoring function	Not yet requested
7	Monitoring-rule catalogue	Whether monitoring rules are defined, linked to fraud scenarios, assigned to a reviewing role and maintained through controlled tuning.	Security monitoring / the security monitoring function	Not yet requested
8	Monthly tuning and coverage report	Whether priority event feeds were monitored for the stated period, high-risk alerts were triaged to the required service level, coverage gaps were recorded and rule tuning was completed from confirmed outcomes.	Security monitoring / the security monitoring function	Not yet requested
9	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Investigation lead / Evidence custodian	Not yet requested
10	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Investigation lead / Evidence custodian	Not yet requested
11	Hash or seal records	Whether collected evidence has integrity markers that can be matched at later custody points.	Investigation lead / Evidence custodian	Not yet requested
12	Repository access log	Whether access to preserved evidence is restricted, attributable and reviewable.	Investigation lead / Evidence custodian	Not yet requested
13	Retention/legal-hold instruction	Whether preservation instructions define the required retention or legal-hold treatment for relevant records.	Investigation lead / Evidence custodian	Not yet requested
14	Consolidated report to governance with actions and due dates	Whether sufficient, attributable evidence is present in the consolidated report to governance with actions and due dates to test the linked control across the complete in-scope population for the stated period.	Risk / compliance accountable owner	Not yet requested
15	Key control operating evidence sampled in the period	Whether sufficient, attributable evidence is present in the key control operating evidence sampled in the period to test the linked control across the complete in-scope population for the stated period.	Risk / compliance accountable owner	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity ceilings and advisory model use only the recorded assessment inputs and the MK Fraud Readiness methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the specified operating proof before treating a control as effective or a finding as resolved.

Control design standard. Priority controls are specified by responsibility, population or scope, operating frequency, retained evidence, independent challenge, escalation trigger, service level, effectiveness measure and response to failure.

Companion register. The complete Essential delivery includes the Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx). It carries the complete finding, risk, control-action, evidence, roadmap and question-trace registers that are intentionally bounded in this PDF.

Recommended next step. Commission independent validation of the control linkage showing preventive and detective controls. Confirm whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable. This is the immediate proof priority; the complete sequence is set out in Proof requirements above and the full checklist in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx).

APPENDIX

Appendix: supporting material

Bounded supporting material for the priority matters above. The complete authoritative registers are provided in the supporting register, not reproduced here.

Complete supporting detail

This report presents the highest-priority matters from a complete assessment inventory of 68 controls (66 applicable and 2 excluded). The full assessment identified 34 material findings, 33 risks, 34 control improvements, 142 evidence artefacts, 34 recommended actions and 74 functional-agenda items.

Every item not shown in this report is retained in full in the Essential Supporting Register (RPT-MKFRS-V12-COMP-SIYAKHULA-V1-supporting-register.xlsx). No identified weakness has been discarded.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Access to sensitive systems, administrator rights and confidential data is restricted".	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.	Technology / security accountable owner / 60 days
2	Fraud Detection Capability	Close the material control weakness recorded for "The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags".	The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the management fraud-risk review route.	Finance / operations accountable owner / 90 days
3	Digital and Identity Fraud Risk	Close the material control weakness recorded for "The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm".	The process owner must define the risk points requiring verification — customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting — and apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records, and confirmation of contact details through independently obtained channels; results and evidence are retained under applicable data-protection obligations, exceptions require documented approval, and sensitive profile or banking changes trigger re-verification.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
4	Digital and Identity Fraud Risk	Close the material control weakness recorded for "The organisation can detect identity misuse, account takeover or impersonation".	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	Technology / security accountable owner / 90 days
5	Fraud Detection Capability	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance / operations accountable owner / 60 days
6	Continuous Improvement and Fraud Risk Monitoring	Close the material control weakness recorded for "Fraud incidents or control failures are analysed to understand root causes and control weaknesses".	The Risk / compliance accountable owner must apply a structured root-cause method to every material incident and significant near-miss, classifying each cause as control absent, control designed but not operating, control operating but ineffective, or deliberate override, and identifying why detection was delayed; findings are recorded in a common register, aggregated at least twice a year to surface recurring themes across cases, and themes drive programme-level action rather than case-level fixes alone.	Finance / operations accountable owner / Risk / compliance accountable owner / 60 days
7	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
8	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
9	Operational Fraud Controls	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance / operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance / operations accountable owner / 60 days
10	Operational Fraud Controls	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk / compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Finance / operations accountable owner / People / workforce accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
11	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk / compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Governing body / independent oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk / compliance accountable owner / 30 days
12	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Governing body / independent oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Governing body / independent oversight / 90 days
13	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance / operations accountable owner / 90 days
14	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees receive training on phishing, social engineering and digital impersonation attempts".	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Technology / security accountable owner / People / workforce accountable owner / 90 days
15	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Employees and users know how to report suspicious digital activity or account-security concerns".	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Technology / security accountable owner / 60 days
16	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Emerging digital fraud risks relevant to the organisation's operations or sector are reviewed periodically".	The information security and digital owners must jointly run a periodic review of emerging digital fraud methods relevant to the organisation's channels, drawing on vendor and industry advisories, incident experience and peer reporting; each method is assessed against current preventive and detective controls, gaps become owned actions with due dates, and accepted risks are recorded with rationale and reported to the risk forum.	Technology / security accountable owner / 90 days
17	Operational Fraud Controls	Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
18	Operational Fraud Controls	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance / operations accountable owner / People / workforce accountable owner / 60 days
19	Operational Fraud Controls	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance / operations accountable owner / 60 days
20	Operational Fraud Controls	Close the material control weakness recorded for "Stock and physical assets are safeguarded and reconciled by defined people".	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance / operations accountable owner / 90 days
21	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are updated when new fraud risks, fraud methods or operational changes emerge".	The monitoring owner must reassess the detection set whenever a new fraud method is identified internally or externally, a material process or system changes, or a confirmed incident bypassed existing detection; each change is documented with rationale, tested against historical data before deployment, version-controlled, and reported with before-and-after coverage to the management fraud-risk review route.	Finance / operations accountable owner / 90 days
22	Fraud Incident Response	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Finance / operations accountable owner / Legal / investigations accountable owner / 30 days
23	Fraud Incident Response	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days
24	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "The organisation receives and reviews risk information about high-risk third parties managed on its behalf".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance / operations accountable owner.	Finance / operations accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
25	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology / security accountable owner / 60 days
26	Digital and Identity Fraud Risk	Close the material control weakness recorded for "The organisation can investigate and contain identity misuse, account takeover or impersonation".	Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	Technology / security accountable owner / Finance / operations accountable owner / 90 days

E2. Definitions and score basis

How the score is calculated

Each applicable assessment response is normalised to a 0–100 control score and weighted within its domain. Domain scores are then combined using the methodology's domain weights to produce the overall readiness score. A control recorded as not applicable is excluded from its scoring denominator rather than treated as a weakness.

The weighted overall score is 42.73/100, which maps numerically to Developing. The final maturity shown in this report is Developing. The next numerical band begins at 60/100; a higher numerical score alone does not override a stricter applicable maturity ceiling.

Maturity scale

MATURITY	SCORE RANGE	INTERPRETATION
Reactive	0–<40	Foundational controls are limited or mainly reactive.
Developing	40–<60	Core control elements exist but are incomplete, inconsistent or not yet connected.
Structured	60–<80	Controls are more consistently defined, owned and operated.
Strategic	80–100	Fraud-risk management is embedded, monitored and continually improved.

Maturity ceilings

Maturity ceilings protect against a strong average masking a material weakness. A hard-gate critical control scored 0 or 1 sets a maximum of Developing; a hard-gate control scored 2 sets a maximum of Structured; three or more critical controls scored 0, 1 or 2 set a maximum of Developing; any core domain below 40 sets a maximum of Developing; and any core domain below 60 sets a maximum of Structured. Where several ceilings apply, the strictest ceiling governs the final maturity.

Reported domain scores

DOMAIN	REPORTED SCORE	MATURITY
Fraud Leadership and Governance	62/100	Structured
Fraud Risk Identification	39/100	Reactive
Operational Fraud Controls	41/100	Developing
Fraud Detection Capability	21/100	Reactive
Fraud Incident Response	44/100	Developing
Whistleblowing and Reporting Culture	81/100	Strategic
Third-Party and Supply Chain Fraud Risk	47/100	Developing
Digital and Identity Fraud Risk	26/100	Reactive
Fraud Culture and Awareness	77/100	Structured
Continuous Improvement and Fraud Risk Monitoring	21/100	Reactive

Risk priority uses the MK qualitative likelihood/impact matrix. Risks in the same priority class are not further ranked by their display sequence. Priority and materiality are derived from assessment evidence; neither is an independent risk assessment.